

Web-based Attacks on Android Devices

Android devices heavily rely on web connectivity and web apps, making them vulnerable to various web-based attacks.

1. Cross-Site Scripting (XSS)

- Occurs when malicious scripts are injected into trusted websites or apps with embedded web views.
- On Android, apps using WebViews may be vulnerable if they do not properly sanitize input or restrict JavaScript execution.
- Can lead to data theft, session hijacking, or execution of unwanted actions.

2. Cross-Site Request Forgery (CSRF)

- Tricks authenticated users into submitting malicious requests unknowingly.
- Apps with embedded browsers or WebViews are at risk if no anti-CSRF tokens are used.

3. Phishing via Malicious Websites

- Attackers create fake websites mimicking legitimate ones to steal credentials.
- Android users clicking phishing links on browsers or apps risk account compromise.

4. Drive-by Downloads

- Visiting a compromised or malicious website can trigger automatic downloads of malware or exploit kits without user consent.

5. Man-in-the-Browser (MitB) Attacks

- Malware inside the browser intercepts or modifies web communications.
- On Android, malicious apps with accessibility or overlay permissions can perform MitB attacks.

6. Malicious Ad Injection

- Ads served through ad networks can contain malicious code or redirect to harmful sites.
- Apps using third-party ad libraries might expose users to this.

7. Browser Exploits

- Vulnerabilities in mobile browsers or embedded WebView components can be exploited to execute code or escalate privileges.

Network-Based Attacks on Android Devices

Android devices depend on Wi-Fi and mobile networks, exposing them to network-level attacks.

1. Man-in-the-Middle (MITM) Attacks

- Attacker intercepts communication between the device and server, capturing sensitive data or injecting malicious content.
- Often performed on unsecured or public Wi-Fi networks.
- Can be mitigated with proper SSL/TLS certificate validation and certificate pinning.

2. Wi-Fi Eavesdropping

- Listening to unencrypted network traffic to steal data.
- Android apps that send data in plaintext are highly vulnerable.

3. Rogue Access Points (Evil Twins)

- Fake Wi-Fi access points impersonate legitimate hotspots to lure victims and intercept data.

4. DNS Spoofing / Poisoning

- Attacker manipulates DNS responses to redirect the device to malicious sites.
- Leads to phishing, malware downloads, or fraudulent websites.

5. ARP Spoofing / Poisoning

- Attacker poisons the ARP cache of devices to intercept network traffic or launch MITM

attacks.

6. Session Hijacking over Networks

- Capturing session tokens or cookies over unsecured networks to gain unauthorized access.
-

Social Engineering Attacks on Android Devices

Social engineering exploits human psychology to trick users into compromising security.

1. Phishing

- Emails, SMS (smishing), or messaging apps trick users into clicking malicious links or providing credentials.

2. Vishing (Voice Phishing)

- Attackers use phone calls to impersonate trusted entities to extract sensitive information.

3. Pretexting

- Creating a fabricated scenario to gain trust and gather confidential data.

4. Baiting

- Luring users with promises of freebies or rewards to install malicious apps or click harmful

links.

5. Quizzes, Surveys, or Fake Offers

- Using social platforms or apps to lure users into giving up private information.

6. Impersonation on Social Media

- Attackers impersonate contacts to send malicious links or requests.

7. Malicious App Installation through Social Engineering

- Convincing users to download apps from unofficial sources that contain malware.

Summary Table

Attack Type	Description	Android-Specific Example	Mitigation Strategy
Web-based Attacks	Exploits browser or app web components	XSS in WebView, malicious ads	Input validation, secure WebViews
Network-based Attacks	Intercept or redirect network traffic	MITM on public Wi-Fi, rogue access points	Use VPN, SSL pinning, avoid public Wi-Fi
Social Engineering	Manipulates users to reveal info or install malware	Phishing SMS, fake app installs	User awareness, app permissions review